

AWS re:Invent

NOV. 28 – DEC. 2, 2022 | LAS VEGAS, NV

NET315-R

Strengthen your web application defenses using AWS WAF

Diana Alvarado (she/her)

Sr. Security Solutions Architect
AWS

David Heidt (he/his)

Sr. Game Tech Solutions Architect
AWS



© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

What exactly is a chalk talk?

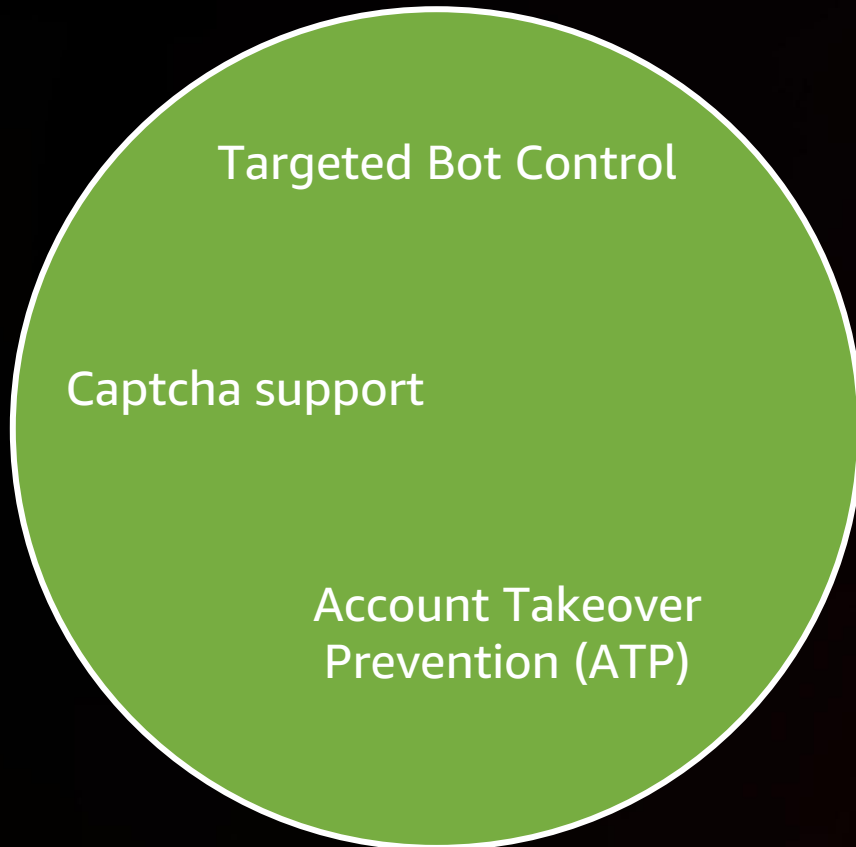


What you can expect from this talk

- Highlight of AWS WAF features from 2022
 - How each feature can be used
 - Discussion of common use cases and configurations
 - Q&A
-
- | Topic | Percentage |
|---|------------|
| Highlight of AWS WAF features from 2022 | 30% |
| How each feature can be used | |
| Discussion of common use cases and configurations | 70% |
| Q&A | |

New 2022 AWS WAF features highlight

Dynamic request evaluation



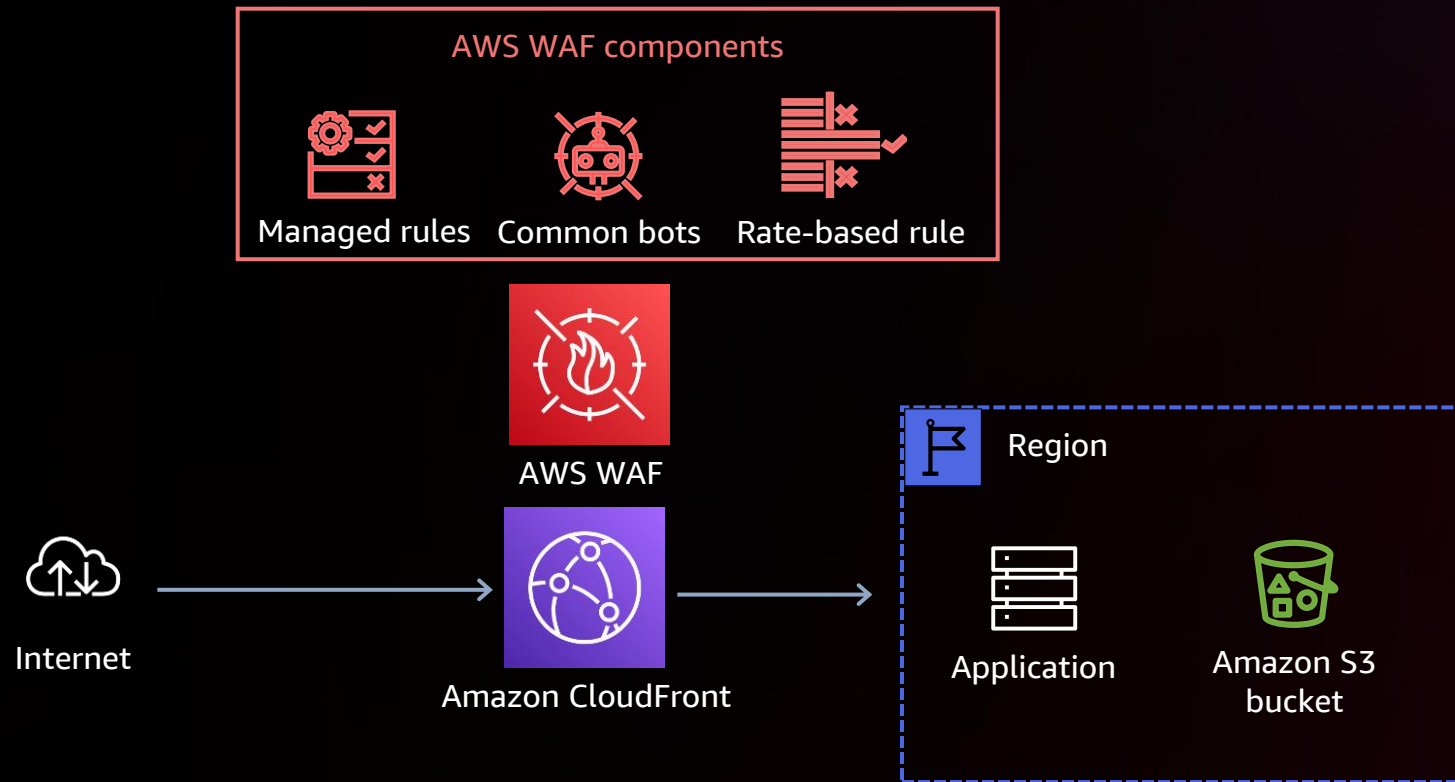
Static request evaluation



Putting these into action



Our Food app is already using AWS WAF



My login page has some strange activity

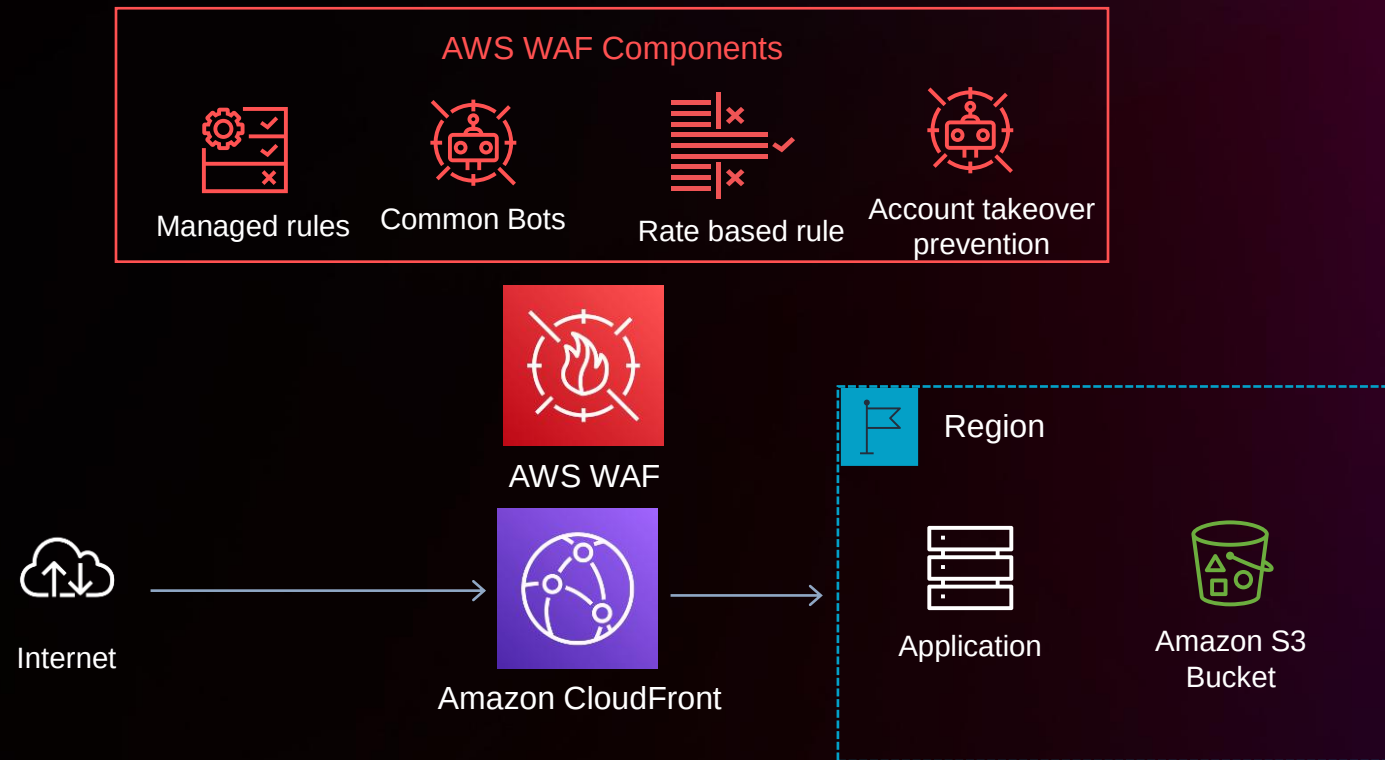


Account takeover prevention (ATP)

- Detect and mitigate against **login attempts** made by malicious actors using stolen credentials
- Available as a managed rule group
- Uses a unique ID to track sessions
- Silently challenges the client (JS, iOS, Android) using SDK integration

Rules		☒ Set all rule actions to count
Name	Rule action	
UnsupportedCognitoIDP	☒	Count
VolumetricIpHigh	☒	Count
VolumetricSession	☒	Count
AttributeCompromisedCredentials	☒	Count
AttributeUsernameTraversal	☒	Count
AttributePasswordTraversal	☒	Count
AttributeLongSession	☒	Count
TokenRejected	☒	Count
SignalMissingCredential	☒	Count

Adding ATP for login protection

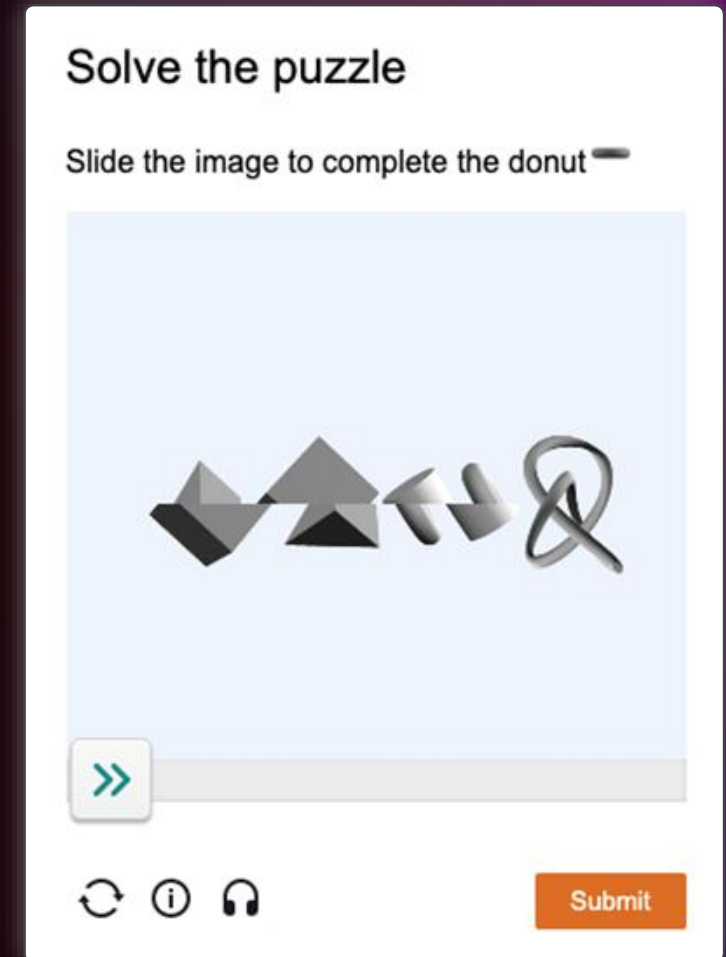


I see an unexplained increase in sign-ups

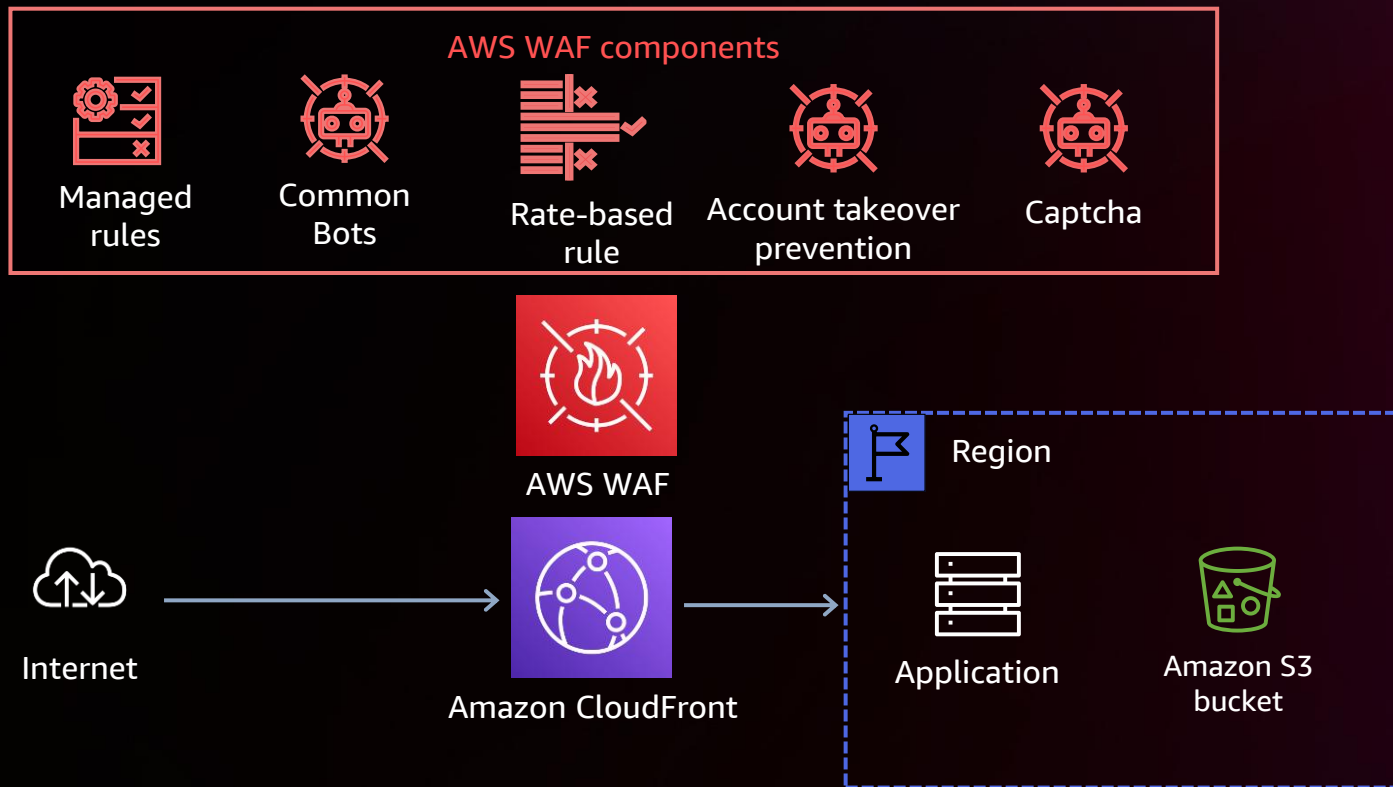


AWS WAF Captcha

- Use Captcha as an advanced rule action:
 - For rate limiting based on labels
 - For challenges on sensitive URLs like sign-up
 - For traffic from suspicious countries or sources
- Apply only to required URIs for cost control



One more layer of protection



Our food images are being stolen



Targeted Bot Control

- Detects bots that try to evade detection
- Behavior-based detection capabilities
- Browser Fingerprinting and Interrogation, Dynamic rate-limiting, fallback to Captcha

Targeted

TGT_VolumetricIpTokenAbsent

Challenge ▼

TGT_VolumetricSession

CAPTCHA ▼

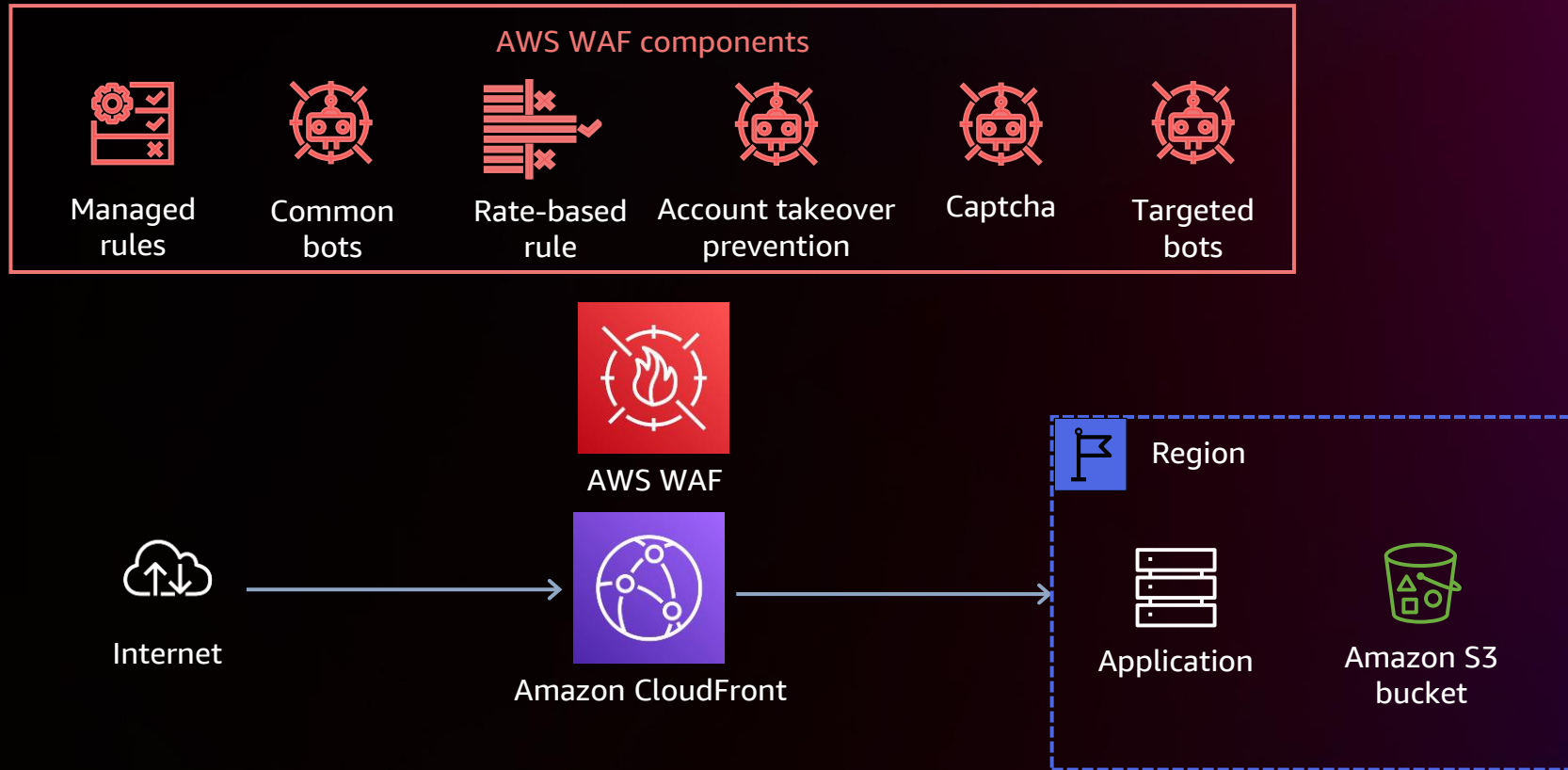
TGT_SignalAutomatedBrowser

CAPTCHA ▼

TGT_SignalBrowserInconsistency

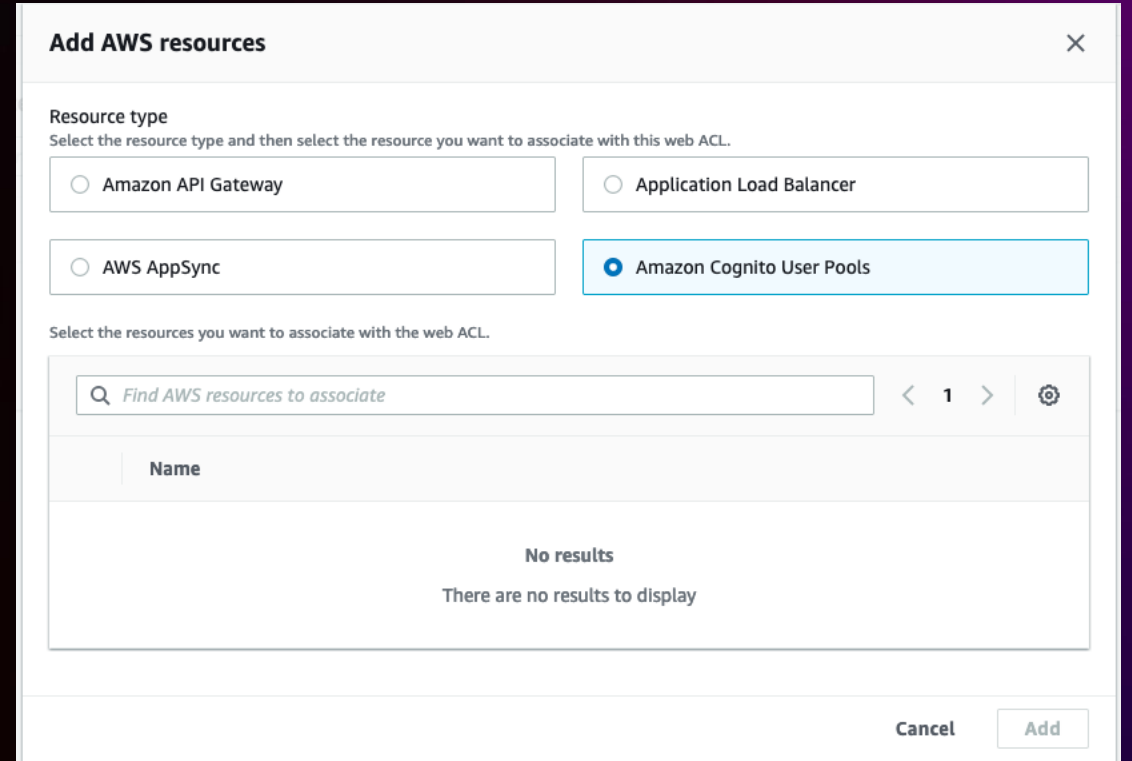
CAPTCHA ▼

Adding improved protection for bots



Protecting my Amazon Cognito UserPool

- Provides protection for Amazon Cognito User Pools
- Provides activity visibility(metrics, logs)
- Mitigation for common attack vectors
- Advanced protection targeted bots, captcha



The screenshot shows the 'Add AWS resources' dialog box in the AWS IAM console. The dialog has a title bar with a close button (X). Below the title bar, the 'Resource type' section is active, with the instruction 'Select the resource type and then select the resource you want to associate with this web ACL.' There are four radio button options: 'Amazon API Gateway', 'Application Load Balancer', 'AWS AppSync', and 'Amazon Cognito User Pools'. The 'Amazon Cognito User Pools' option is selected. Below this, the 'Select the resources you want to associate with the web ACL.' section is shown. It contains a search bar with the placeholder text 'Find AWS resources to associate'. Below the search bar is a table with a header 'Name'. The table is currently empty, and a message 'No results' with the text 'There are no results to display' is shown below the table. At the bottom right of the dialog are 'Cancel' and 'Add' buttons.

Add AWS resources

Resource type
Select the resource type and then select the resource you want to associate with this web ACL.

☐ Amazon API Gateway

☐ Application Load Balancer

☐ AWS AppSync

☒ Amazon Cognito User Pools

Select the resources you want to associate with the web ACL.

Find AWS resources to associate

< 1 > ⚙

Name

No results
There are no results to display

Cancel Add

More than a web application firewall ...



Let's discuss your use cases and requirements!

Resources

- Guidelines for Implementing AWS WAF
- The three most important AWS WAF rate-based rules
- Analyzing AWS WAF Logs in Amazon CloudWatch Logs
- Intelligent threat mitigation options



Relevant sessions

NET316 – APIs: Critical for data transfer, but how do you keep them secure?

GEO001 – Build a better and more secure user experience at the edge

NET318 – Building DDoS-resilient applications using AWS Shield

NET314 – Protect your application security perimeter with AWS WAF

Thank you!

Diana Alvarado

David Heidt



Please complete the session survey in the **mobile app**



© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.